

Internal Brain

Technical Plan

A permission-aware AI knowledge system over Confluence, Jira, Slack and Google Drive

Tencent Cloud AI CAN DO IT Hackathon Singapore 2026 · FinTech track (Aspire)

Workstream	Owner	Directories
A · Sources and freshness	Praew (@watersalamander)	connectors/, simulators/
B · Brain and policy	Ananya (@ananyaredhu)	brain/, mcp_server/
C · Experience and proof	Guanyue (@guanyue017-dev)	ui/, evals/, deploy/

Thesis: the model proposes, a deterministic policy plane disposes.

Key dates: contracts freeze Sun 4 Oct · demoable build Fri 9 Oct · submission Fri 16 Oct 2026

Generated from the repository docs on 02 Oct 2026 (commit 4fc2b4c plus local updates). The Markdown files in docs/ are the source of truth; regenerate this PDF after changing them.

Contents

00 · Overview	6
The challenge (Aspire, FinTech track)	6
Thesis	6
What is new here (calibrated)	6
Scope	7
Judging map (10 criteria x 10 points)	7
Tencent products (mandatory and optional)	7
01 · Architecture	8
Zones and trust boundaries	8
Query path (LangGraph state machine; policy nodes are plain code)	8
Freshness	8
Audit and compliance	8
Data plane	9
Key trade-offs (for the architecture diagram submission)	9
Sandboxing	9
Contracts	10
Rules	10
Connector interface	11
Protocol (Python)	11
Data types	11
Chunk (indexed unit, written by A's ingestion, read by B's retrieval)	12
Behavior requirements	12
Contract tests (connectors/tests/contract/)	12
Changelog	12
ACL model	13
Principle: do not flatten	13
Tokens	13
Per-source semantics (what the evaluator must honor)	13
Identity mapping	13
Labels on derived artifacts (information-flow control)	13
Decisions are recorded with evidence	14
Uniform refusal	14
Changelog	14
Audit event schema	15
Event	15
Hash chain	15
Denied documents	15

Replayability	16
/verify	16
Querying	16
Changelog	16
Context packet	17
Shape	17
Construction rules	17
Working memory	17
Quality metrics (evals)	18
Changelog	18
Runtime skills format	19
Layout	19
SKILL.md	19
Loading and routing	19
First four skills	19
Changelog	19
HTTP API	21
POST /v1/ask	21
GET /v1/mywork	21
GET /v1/explain-access?doc_id=...	21
GET /v1/alerts	21
Audit (compliance role only)	21
Admin and ops (admin role)	21
Demo and test helpers (simulators only, never in production)	22
Changelog	22
MCP tools	23
Design	23
Tools	23
Client configuration	23
Use in the demo	23
Changelog	24
Workstream A · Sources and freshness	25
Mission	25
Scope	25
Owns (produces)	25
Consumes	25
Tasks and schedule	25
Definition of done	26
Watch-outs	26

Workstream B · Brain and policy	27
Mission	27
Scope	27
Owns (produces)	27
Consumes	27
Tasks and schedule	27
Definition of done	28
Watch-outs	28
Workstream C · Experience and proof	29
Mission	29
Scope	29
Owns (produces)	29
Consumes	29
Tasks and schedule	29
Definition of done	30
Watch-outs	30
04 · Scenarios and golden tests	31
Additional demo moments	32
Pass bars	32
Decision records (ADRs)	33
ADR-001 · Model gateway and model tiers	34
Context	34
Decision	34
Consequences	34
To verify	34
ADR-002 · Embeddings: local bge-m3 by default	35
Context	35
Decision	35
Consequences	35
To verify	35
ADR-003 · Layered answer checker	36
Context	36
Decision	36
Consequences	36
To verify	36
ADR-004 · Stateless MCP server	37
Context	37
Decision	37

Consequences	37
To verify	37
ADR-005 · Real Slack and Drive, simulated Confluence and Jira	38
Context	38
Decision	38
Consequences	38
To verify	38
ADR-006 · Storage: single Postgres with pgvector	39
Context	39
Decision	39
Consequences	39
To verify	39
ADR-007 · Orchestration: LangGraph; ADP as an optional backend	40
Context	40
Decision	40
Consequences	40
To verify	40
06 · Risks and week-1 checks	41
Checks	41
Risks	42
Day-1 decisions made	43
07 · Submission	44
Hard requirements (handbook section 8)	44
Required items	44
Track-specific deliverables (Aspire FinTech)	44
Where to submit	44
Judging (10 criteria x 10 points)	44
Proof log	45
Final checklist	45

00 · Overview

docs/00-overview.md

The challenge (Aspire, FinTech track)

Build an **Internal Brain**: an AI system that unifies context across **Confluence, Jira, Slack and Google Drive**, answers natural-language questions with citations, and enforces each platform's access controls end to end, with a tamper-evident audit trail.

Company knowledge is scattered; staff lose about 30% of their week searching. But "an assistant that can read everything can leak everything", so every answer must be scoped to what the asker may see, and every retrieval and answer must be recorded.

What the handbook requires

- Heterogeneous source integration that **does not flatten** each platform's permission model.
- **Permission-aware retrieval**: know the asker, filter *before* the LLM sees anything, and handle permissions changed after ingestion.
- Cross-platform context assembly with permission checks on every piece.
- Security logging and audit: tamper-evident, complete (who, what, retrieved IDs, answer, time, allow/deny per document), queryable.
- LLM safety: mitigate the model "filling in" content it was not given.
- Five scenarios, each with a worked example: see [04-scenarios](#).
- Deliverables: live demo, architecture and trust-boundary diagram with trade-offs, full source on GitHub.

Thesis

The model proposes, a deterministic policy plane disposes.

The LLM never sees unauthorized content, holds no credentials and has no write tools. Every claim in an answer traces to a chunk that was authorized at read time, and every decision is written to a hash-chained audit log.

What is new here (calibrated)

Already common in 2026, so **not** claimed as new: query-time ACL filtering (Glean, Onyx Enterprise, Microsoft Copilot), hash-chained agent audit libraries, general discussion of MCP identity propagation.

What we add:

1. **Answer-level ACL labels.** Every derived artifact (answer, summary, cache entry, memory, vector) carries the intersection of its sources' ACLs.
2. **Closed, measured revocation window.** Re-verify at read time and publish revocation-to-enforcement time.
3. **Link-edge authorization.** Follow cross-platform links only if the target is also authorized.
4. **Post-generation leakage scan** against the denied set, run locally, with canary strings for testing.
5. **Replayable authorization audit.** Entries store the ACL snapshot hash and policy version; time-travel queries ("what could X see on date D?") with proof paths.
6. **Noninterference CI ("Leak-CI").** A user's answer must not change when documents they cannot see are added, removed or edited. Tested metamorphically.
7. **Stale-answer alerts.** If a source behind an answer changes, notify the people who received it.
8. **Identity-propagating, stateless MCP server.** CodeBuddy and WorkBuddy become real clients, with per-user identity and no shared master key.
9. **Red-team harness with a public scoreboard.**

We cannot prove nothing like this exists; we claim only that we found these gaps open in the products and papers we checked.

Scope

Everything in tiers 1 to 3 is in scope; the tiers set **build order**, not what to cut.

- **Tier 1 (core):** connectors, policy decision point, retrieval, query path, five scenarios, audit chain, UI, deployment.
- **Tier 2 (differentiators):** Leak-CI, answer-level ACL labels, stale-answer alerts, replayable audit.
- **Tier 3:** runtime skills, context profile and context engineering, MCP server, My Work home.
- **Stretch:** sensitivity-aware model routing, mosaic/aggregation guard, honeytoken documents, voice (TRTC), access receipts for users.

About 45 person-days of work for 3 people over 15 days; the risk is schedule. A **demoable build by Day 8** and a schedule review then.

Judging map (10 criteria x 10 points)

Criterion	Where we score
Impact & Relevance	30% search-time problem plus the "can it leak everything" fear
Human-Centered Design	Persona UI, "why can I see this?" explanations, My Work
AI Interaction	Routing, context engineering, skills, checker, MCP
Technical Execution	Policy plane, JIT checks, hash chain, contract tests, evals
Feasibility	Real connectors where free, production path (OpenFGA/SpiceDB, real tenants)
Demo & Storytelling	Split-screen personas across all scenarios
Innovation	The list above
UX & Accessibility	Keyboard, ARIA, high contrast, optional voice
Responsible AI & Ethics	Zero-leak, abstention, red-team scoreboard, audit
Overall Impression	Polish, live URL, demo video

Track-specific criteria are shared after registration: ask in the track's WhatsApp group.

Tencent products (mandatory and optional)

- **Mandatory:** the project must be built on **CodeBuddy** or **WorkBuddy**, with proof (3+ screenshots or recordings of chat logs). We use both. See [07-submission](#).
- **Optional:** ADP (agent platform, DeepSeek models), TRTC ASR/TTS (voice), Miora (visuals), Hunyuan models/embeddings, Tencent Cloud Singapore for hosting.

01 · Architecture

docs/01-architecture.md

Zones and trust boundaries

[Diagram: the zones and trust-boundary diagram is a Mermaid chart that renders on GitHub. See docs/01-architecture.md in the repository.]

Rules that define the boundaries:

- **Zone 4 (LLM plane)** gets only sanitized, already-authorized context. No credentials, no network except to the policy plane, no write tools.
- **Zone 2 (policy plane)** is plain deterministic code. No LLM may influence an allow/deny decision.
- Denied content never leaves Zone 2, and is never sent to any model or third party. The leakage scan against denied content runs locally.
- Credentials for source systems live only in connectors (Zone 2), with read-only least-privilege scopes.

Query path (LangGraph state machine; policy nodes are plain code)

1. **Authenticate and resolve identity:** JWT, then per-platform identities (email, Slack ID, Jira accountId) and group memberships.
2. **Context profile and routing (small model):** intent, which platforms and which skill, resolve references ("our migration"), semantic query plus keyword variants.
3. **ACL-prefiltered hybrid retrieval:** per-platform fan-out, BM25 + vectors filtered on the asker's ACL tokens (GIN index), reciprocal-rank fusion, optional rerank.
4. **Just-in-time verification (PDP):** for each top-k candidate, call the connector's `check_access` (short-TTL cache) and compare the source `version` to the indexed version. Stale content is re-fetched inline (read-through). Allow/deny recorded per document.
5. **Link-edge expansion:** follow Jira, Slack, Confluence and Drive links only if the target also passes the PDP.
6. **Context engineering:** build the **context packet** (per-source quotas, dedupe, snippet compression, ordering, token budget, ACL labels, freshness). See [context-packet](#).
7. **Sanitize and spotlight:** wrap chunks in delimiters, strip instruction-like text, flag it.
8. **Generate:** structured claims, each with source chunk IDs (the selected skill shapes the procedure and format).
9. **Check:** layer 1 deterministic (citations exist and are visible; local denied-set leakage scan); layer 2 local grounding model; layer 3 small chat model for hard cases. If support is missing, abstain or redact.
10. **Uniform refusal:** denied and nonexistent content produce the same shape and similar timing; no counts, no titles.
11. **Audit write:** who, query, retrieved IDs, allow/deny per document, ACL snapshot hash, policy version, answer hash, model versions, timestamp, chained by hash.

Freshness

Event-driven ingestion (Slack Events API, Drive `changes.watch`, simulator webhooks) plus an incremental poll as a fallback. Every citation shows an "as of" time. A dashboard shows freshness lag p50/p95. Read-through version checks at query time bound staleness regardless of ingestion lag.

Audit and compliance

Hash-chained log with signed checkpoints and a `/verify` endpoint. Natural-language audit queries are answered by a read-only audit agent that is itself under RBAC. Denied document IDs are stored salted-hashed. Entries store the ACL snapshot hash and policy version so decisions are replayable.

Data plane

Postgres with pgvector, full-text search and a GIN index on `acl_tokens[]`. Source-native ACL evidence is stored next to normalized tokens. Embeddings: local **bge-m3** by default. Every vector stores `embedding_model` and `embedding_version`. See [ADR-002](#) and [ADR-006](#).

Key trade-offs (for the architecture diagram submission)

Choice	Trade-off
Prefilter plus JIT re-check	Extra latency and source API calls, in exchange for closing the revocation window
Own policy decision point, not OpenFGA/SpiceDB	Faster to build and keeps native semantics, but less general; production path is OpenFGA/SpiceDB
Local embeddings and local checker	Privacy and no rate limit, but CPU cost on the deployment server
Real Slack/Drive, simulated Confluence/Jira	Fidelity where free APIs allow it; simulators give scale and permission semantics the free Atlassian plan lacks
Stateless MCP	Per-request authorization and easy scaling; no server-initiated streaming
Single Postgres	One system to run and secure; less specialized than a dedicated vector DB

Sandboxing

LLM-plane code runs with no egress except to the policy plane and the model gateway. Candidate: Tencent's open-source CubeSandbox (KVM isolation, per-sandbox network policy, egress allow-list that keeps keys out of the sandbox); fallback Docker with network policy. The handbook lists "Tencent Cloud Agent Runtime": confirm whether it is the same or compatible. See [06-risks-and-checks](#).

Contracts

docs/02-contracts/README.md

These files are the **agreements between workstreams**. Code in one workstream depends on these shapes, not on another workstream's internals.

Contract	Defines	Producer	Consumers
connector-interface	Connector protocol, Document , Chunk , AccessDecision	A	B
acl-model	Principals, ACL tokens, per-source semantics, labels on derived artifacts	A (evaluators), B (PDP)	A, B, C
audit-event-schema	Audit event fields, hash chain, /verify	B	C
context-packet	What the LLM plane receives	B	B
skills-format	Runtime skill files	B	B, C
api	HTTP API used by the UI	B	C
mcp-tools	MCP tool definitions	B	C (WorkBuddy/CodeBuddy setup)

Rules

- **Freeze: Day 3 (Sun 4 Oct)**. After that, any change is a PR approved by **all three** (enforced by CODEOWNERS).
- Version each contract with a **version:** line at the top. Bump it on any change and note it in the changelog at the bottom of the file.
- Each workstream ships a **stub** of its side by Day 3, returning fixture data that matches the contract, so the others can build against it.
- Examples in these files are fixtures: copy them into tests.
- Field names are **snake_case**. Timestamps are UTC ISO-8601. IDs are opaque strings.

Connector interface

docs/02-contracts/connector-interface.md

version: 0.1 (draft, freezes Day 3)

Producer: Workstream A. Consumers: B (ingestion, PDP, JIT checks).

Every source (Slack, Google Drive, Confluence, Jira), real or simulated, implements the same protocol and passes the same **contract tests**. Simulators must be proven faithful by running the same tests against the real API wherever one exists.

Protocol (Python)

```
from typing import Protocol, Literal, Iterable

Source = Literal["slack", "gdrive", "confluence", "jira"]

class Connector(Protocol):
    source: Source

    def resolve_identity(self, email: str) -> "PlatformIdentity | None":
        """Map a corporate email to this platform's identity (Slack user ID, Jira accountId...)."""

    def list_changes(self, cursor: str | None) -> "ChangeBatch":
        """Incremental changes since cursor (created/updated/deleted docs AND permission changes)."""

    def fetch(self, doc_id: str) -> "Document":
        """Current content, links and ACL evidence for one document."""

    def check_access(self, identity: "PlatformIdentity", doc_id: str) -> "AccessDecision":
        """Authoritative, live answer: may this identity read this doc right now?
        Called just-in-time by the PDP. Must be fast (<300 ms typical) and cacheable by the caller (short TTL)."""

    def version(self, doc_id: str) -> str:
        """Cheap source version (etag / updated timestamp) used to detect staleness."""
```

Data types

```
class PlatformIdentity:
    source: Source
    platform_user_id: str
    email: str
    groups: list[str]          # platform-native groups, roles, channels, as the platform sees them

class Document:
    doc_id: str                # globally unique: "<source>:<native id>"
    source: Source
    kind: str                  # page | issue | message | thread | file | comment
    title: str
    url: str
    body: str                  # text content (markdown ok)
    parent_id: str | None      # space/project/channel/folder container
    links: list[str]           # doc_ids this doc references (cross-platform links allowed)
    author: str
    created_at: str
    updated_at: str
    version: str
    acl: "AclEvidence"

class AclEvidence:
    tokens: list[str]          # effective allow tokens at observed_at (see acl-model.md)
    native: dict                # source-native raw ACL data kept for audit and replay
    snapshot_hash: str          # sha256 of canonical(native)
    observed_at: str

class ChangeBatch:
    changes: list["Change"]
    next_cursor: str
    has_more: bool

class Change:
    type: Literal["upsert", "delete", "acl_change"]
```

```

doc_id: str
detected_at: str

class AccessDecision:
    allowed: bool
    proof_path: list[str]      # minimal grant path, e.g. ["user:priya", "group:payments-eng", "space:PAY"]
    evaluated_at: str
    acl_snapshot_hash: str
    policy_version: str

```

Chunk (indexed unit, written by A's ingestion, read by B's retrieval)

```

class Chunk:
    chunk_id: str
    doc_id: str
    position: int
    text: str
    acl_tokens: list[str]      # copied from the document's AclEvidence
    acl_snapshot_hash: str
    source_version: str        # Document.version at index time
    embedding: list[float]
    embedding_model: str        # e.g. "bge-m3"
    embedding_version: str
    ingested_at: str

```

Vectors carry the **same ACL tokens as their chunk** and are never shared across ACLs.

Behavior requirements

- `list_changes` must also emit `acl_change` entries when permissions change (channel removal, page restriction, folder share change), not only content changes.
- Deleted or no-longer-visible docs must be reported so they can be dropped from the index.
- `check_access` must never return `allowed=True` on an error or timeout: **fail closed**.
- Rate limits: connectors back off and surface lag as a metric (`freshness_lag_seconds`).
- Credentials are read-only, least-privilege, and live only in the connector process.

Contract tests (`connectors/tests/contract/`)

1. Seeded fixture: known docs with known ACLs, expected `fetch`, `version` and `check_access` results per persona.
2. Revocation: change the ACL, then `list_changes` emits `acl_change` and `check_access` flips to deny within the SLA.
3. Edit: change content, then `version` changes and `list_changes` emits `upsert`.
4. Inheritance: container-level permissions apply to children (Confluence space to page, Drive folder to file).
5. Negative: `check_access` for a nonexistent doc and for a forbidden doc return the same shape.

Changelog

- 0.1: first draft.

ACL model

docs/02-contracts/acl-model.md

version: 0.1 (draft, freezes Day 3)

Owners: A (per-source evaluators), B (policy decision point, labels on derived artifacts).

Principle: do not flatten

Each platform has its own permission semantics. We normalize **only for fast prefiltering**, and always keep the source-native evidence. The authoritative answer is the connector's live `check_access`.

Tokens

An ACL token names a principal that has effective read access. A chunk's `acl_tokens` is the set of principals who may read it at `observed_at`.

Token	Meaning
<code>user:<email></code>	A specific person
<code>group:<source>:<id></code>	A platform group, role or team, e.g. <code>group:confluence:security-team</code>
<code>channel:<slack id></code>	Members of a Slack channel
<code>role:<project>:<role></code>	A Jira project role
<code>public:org</code>	Anyone in the organization
<code>external:<email></code>	A specific external person (Drive external sharing)

The asker's **access token set** is computed from their resolved identities: their `user:` token, their groups from every platform, channel memberships, project roles, `public:org`. Prefilter: `chunk.acl_tokens && asker_tokens` (array overlap, GIN index).

Deny rules (Jira issue security levels, Confluence page restrictions that narrow inherited access) are **resolved at index time** into the effective allow set. The JIT check catches anything the prefilter gets wrong.

Per-source semantics (what the evaluator must honor)

Source	Semantics
Confluence	Space permissions, plus page restrictions (view/edit) that narrow access; restrictions inherit from ancestor pages; anonymous/public spaces
Jira	Project permission scheme via project roles and groups; issue security levels restrict individual issues (e.g. security-sensitive bugs visible only to the security team)
Slack	Public channels (workspace members), private channels (members only), DMs (participants only); threads follow their channel; external/guest users restricted to their channels
Google Drive	Folder and file sharing (viewer/commenter/editor), inheritance from folders, shared drives vs personal drives, link sharing, external sharing for some folders

Simulators must implement these rules, not simplified versions. The contract tests prove it.

Identity mapping

The IdP (mock OIDC) issues a JWT with `sub` and `email`. `resolve_identity(email)` maps it to each platform's user and groups. Missing mapping = **no access on that platform** (fail closed).

Labels on derived artifacts (information-flow control)

Every derived artifact carries `acl_label`: the **intersection** of the ACL tokens of all sources it was derived from.

Derived artifacts: answers, summaries, cache entries, conversation memory, context profiles, vectors, stale-answer alerts.

Rule: an artifact may be served to a user only if the user's access token set satisfies **every** source in its derivation (i.e. the user is authorized for each underlying source). If any source is no longer visible to them, the artifact is not served.

Decisions are recorded with evidence

Each allow/deny decision stores: `doc_id`, `allowed`, `proof_path`, `acl_snapshot_hash`, `policy_version`, `doc_version`, `evaluated_at`. This enables replay ("was this decision correct at the time?") and time-travel queries.

Uniform refusal

A denied document and a nonexistent one produce the same response shape, similar timing, and no counts or titles. Link-edge expansion follows a link only if the target passes the PDP.

Changelog

- 0.1: first draft.

Audit event schema

docs/02-contracts/audit-event-schema.md

version: 0.1 (draft, freezes Day 3)

Producer: Workstream B (audit service). Consumers: C (console, evals), B (audit agent).

The log must be **tamper-evident**, **complete** (who, what, retrieved IDs, final answer, time, allow/deny per document) and **queryable**.

Event

```
{
  "seq": 1042,
  "ts": "2026-10-10T14:05:11.482Z",
  "request_id": "req_9f2c",
  "event_type": "ask",
  "actor": {"user_id": "priya@companya.com", "roles": ["engineer"], "client": "ui"},
  "query": {"text": "What's the status of the DB migration ...", "skill": "status-and-blockers"},
  "decisions": [
    {
      "doc_id": "jira:DBMIG-142",
      "allowed": true,
      "proof_path": ["user:priya@companya.com", "role:DBMIG:developer"],
      "acl_snapshot_hash": "sha256:...",
      "policy_version": "pol-0.3",
      "doc_version": "2026-10-10T13:58:00Z",
      "jit_checked": true
    },
    {
      "doc_id_hash": "sha256:salted...",
      "allowed": false,
      "reason": "no_access",
      "acl_snapshot_hash": "sha256:...",
      "policy_version": "pol-0.3"
    }
  ],
  "answer": {
    "text": "...",
    "sha256": "sha256:...",
    "citations": ["jira:DBMIG-142", "slack:C123/1728..."],
    "refused": false,
    "acl_label": ["user:priya@companya.com"]
  },
  "checks": {"deterministic": "pass", "grounding_model": "pass", "leak_scan": "clean"},
  "models": {"generator": "deepseek-v3", "checker": "minicheck-...", "embedding": "bge-m3@1"},
  "latency_ms": 2310,
  "prev_hash": "sha256:...",
  "hash": "sha256:..."
}
```

Event types: `ask`, `search`, `mcp_call`, `audit_query`, `admin_view`, `acl_change_observed`, `alert_sent`, `checkpoint`.

Hash chain

- `hash` = `SHA256( canonical_json(event without "hash") )`, where the canonical form includes `prev_hash`.
- `prev_hash` is the previous event's `hash`. The first event uses a fixed genesis value.
- Every N events (e.g. 100) write a `checkpoint` event signed with an **Ed25519** key (`AUDIT_SIGNING_KEY`). The public key is published so auditors can verify.
- Any edit, deletion, insertion or reordering breaks the chain at that point.

Denied documents

Denied `doc_ids` are stored **salted-hashed**, so an auditor can see that attempts happened without the log becoming a leak. Allowed decisions store the plain `doc_id`.

Replayability

Each decision stores `acl_snapshot_hash`, `policy_version` and `doc_version` so an auditor can re-evaluate "was this decision correct at that time?". Together with ACL snapshots stored with validity intervals (bi-temporal), this supports time-travel queries ("what could jdoe see on 12 Oct?").

`/verify`

GET `/v1/audit/verify` returns `{ok: true, checked: N, checkpoints: M}` or `{ok: false, first_broken_seq: K, reason: "..."}.` Must be fast enough to demo live.

Querying

Audit queries (natural language or structured) are read-only and run **under RBAC**: only the compliance role can query other users' history. Querying the audit log is itself logged (`audit_query`). Sensitive lookups may require a two-person approval (stretch).

Changelog

- 0.1: first draft.

Context packet

docs/02-contracts/context-packet.md

version: 0.1 (draft, freezes Day 3)

Owner: Workstream B. This is the **only thing the LLM plane receives** besides the system prompt.

Context engineering is an explicit pipeline stage: select, compress, order and budget what the model sees, with provenance and permissions attached.

Shape

```
{
  "request_id": "req_9f2c",
  "user_context": {
    "display_name": "Priya",
    "teams": ["payments-eng"],
    "projects": ["DBMIG", "PAY"],
    "recent_focus": ["DBMIG"],
    "glossary_hits": {"our migration": "DBMIG"}
  },
  "task": {
    "question": "What's the status of the DB migration ...?",
    "skill": "status-and-blockers",
    "output_schema": "claims_with_citations_v1"
  },
  "evidence": [
    {
      "chunk_id": "jira:DBMIG-142#0",
      "doc_id": "jira:DBMIG-142",
      "source": "jira",
      "title": "DBMIG-142 Cutover blocked on replica lag",
      "url": "https://...",
      "text": "<spotlighted, sanitized snippet>",
      "as_of": "2026-10-10T13:58:00Z",
      "acl_label": ["role:DBMIG:developer"],
      "flags": []
    }
  ],
  "constraints": {
    "must_cite": true,
    "abstain_if_unsupported": true,
    "max_tokens": 6000
  }
}
```

Construction rules

1. **Only authorized evidence.** Every item passed the PDP just-in-time. Denied content never enters the packet.
2. **Per-source quotas** so one platform cannot crowd out the others; **deduplicate** near-identical chunks.
3. **Compress** to relevant snippets (extractive first), keeping provenance; never merge across documents.
4. **Order** evidence to avoid "lost in the middle" (strongest first and last).
5. **Token budget** enforced; drop lowest-ranked evidence first, never truncate mid-sentence.
6. **Spotlighting and sanitization:** wrap each snippet in delimiters; strip or neutralize instruction-like text; set `flags: ["possible_injection"]` and record it in the audit log. Retrieved text is data, never instructions.
7. **User context is built only from data the user may see** and is itself ACL-labeled. It may boost ranking and resolve references; it never filters out results the user may see, and never grants access.
8. **No secrets and no connector credentials** anywhere in the packet.

Working memory

Conversation memory entries are labeled with the intersection of their sources' ACLs and re-checked on every turn; an entry whose source the user can no longer see is dropped.

Quality metrics (evals)

Context precision and recall on the golden set, citation precision, abstention correctness, and token cost per answer.

Changelog

- 0.1: first draft.

Runtime skills format

docs/02-contracts/skills-format.md

version: 0.1 (draft, freezes Day 3)

Owner: Workstream B. Consumers: B (router and loader), C (admin view).

A **skill** makes the agent specific to a task: a procedure, an output format and an allowlist of tools. Skills are instructions only. **A skill never carries authority**: it cannot widen access, add tools beyond its allowlist, or change policy.

(Not to be confused with build-time CodeBuddy skills, which help us develop the project. Those live with the developer's tooling.)

Layout

```
brain/skills/<name>/
  SKILL.md           frontmatter + procedure
  templates/         optional output templates
  examples/          optional few-shot examples (fixture-safe, no real data)
```

SKILL.md

```
---
name: incident-investigation
version: 1
description: Find the root cause of an incident and list follow-up tickets
triggers: ["root cause", "outage", "incident", "postmortem"]
sources: [jira, slack, confluence, gdrive]
tools_allowlist: [search, get_source, explain_access]
output_schema: claims_with_citations_v1
max_evidence: 12
---
# Procedure
1. Identify the incident from the question and the user's recent focus.
2. Gather the incident ticket, the incident Slack thread, the postmortem and the runbook.
3. State the root cause only if a cited source states it. Otherwise say it is not established.
4. List follow-up tickets with status and owner, each cited.
# Constraints
- Cite every claim. Abstain on anything unsupported.
- Never infer the existence of content you were not given.
```

Loading and routing

- The router (small model) picks a skill from **triggers** and **description**, or none (default procedure).
- The loader reads the skill and injects its procedure into the system prompt. Output must conform to **output_schema**.
- Skills are **versioned and reviewed** like code (PR required). A skill is a prompt-injection surface, so skill files are never writable at runtime and are pinned by hash in the audit log (**skill**, **skill_version**).

First four skills

Skill	Serves
status-and-blockers	Scenario 1 (DB migration status plus Slack blockers)
incident-investigation	CTO question 1 (outage root cause plus follow-up tickets)
design-discussion-summary	CTO question 2 (auth-service design threads plus decision doc link)
audit-inquiry	Scenario 5 (what did user X access); compliance role only

Changelog

- 0.1: first draft.

HTTP API

docs/02-contracts/api.md

version: 0.1 (draft, freezes Day 3)

Producer: Workstream B. Consumer: C (UI, console). The MCP server exposes the same pipeline: see [mcp-tools](#).

Base path `/v1`. JSON. **Auth:** `Authorization: Bearer <JWT>` from the mock IdP on **every** request (validated per request: signature, expiry, audience). JWT claims: `sub`, `email`, `roles`, `aud`.

Errors: `{ "error": { "code": "...", "message": "..." } }`. Refusals are **not errors**: they return 200 with `refused: true` and the uniform refusal shape.

`POST /v1/ask`

Request: `{ "question": "...", "conversation_id": "optional", "skill_hint": "optional" }`

Response:

```
{
  "request_id": "req_9f2c",
  "conversation_id": "c_1",
  "answer": "...",
  "claims": [{ "text": "...", "citations": ["jira:DBMIG-142"] }],
  "citations": [{ "doc_id": "jira:DBMIG-142", "title": "...", "url": "...", "source": "jira", "as_of":
    "2026-10-10T13:58:00Z", "why_visible": ["role:DBMIG:developer"] }],
  "refused": false,
  "abstained": false,
  "freshness": { "oldest_source_as_of": "...", "stale_refetched": 0 },
  "skill": "status-and-blockers"
}
```

Refusal: `{ "refused": true, "answer": "I couldn't find anything you have access to about that.", "claims": [], "citations": [] }`. Same shape and similar timing for forbidden and nonexistent content. No counts, no titles.

`GET /v1/mywork`

Personalized home for the logged-in user: assigned issues, projects, recent pages, channels, suggested questions, pending stale-answer alerts. Everything is fetched through the PDP: nothing the user cannot see.

`GET /v1/explain-access?doc_id=...`

Why can I see this? Returns `proof_path` for an allowed document. For a forbidden or nonexistent one, returns the uniform "not found" response.

`GET /v1/alerts`

Stale-answer alerts: answers the user received whose sources changed afterwards (`request_id`, `changed_doc`, `changed_at`, `summary`).

Audit (compliance role only)

- `POST /v1/audit/query` with `{ "question": "..." }` (natural language) or `{ "filter": { user, space, from, to, decision } }` returns events, with timestamps, retrieved IDs and allow/deny decisions.
- `GET /v1/audit/verify` returns `{ ok, checked, checkpoints }` or `{ ok:false, first_broken_seq, reason }`.
- `GET /v1/audit/time-travel?user=...&at=...` returns what a user could see at a past time (when bi-temporal ACL snapshots are available).

Admin and ops (admin role)

- `GET /v1/freshness` returns lag p50/p95 per source and last sync.
- `GET /v1/leakci/latest` returns the latest Leak-CI and red-team scoreboard.
- `GET /v1/health`.

Demo and test helpers (simulators only, never in production)

Simulator admin endpoints (owned by A) to revoke a permission, restrict a page, edit a document, and add or remove hidden documents (for Leak-CI). Documented in [simulators/README.md](#).

Changelog

- 0.1: first draft.

MCP tools

docs/02-contracts/mcp-tools.md

version: 0.1 (draft, freezes Day 3)

Producer: Workstream B. Consumer: C (WorkBuddy and CodeBuddy setup).

The MCP server is **another front door into the same pipeline as the UI**. It contains no separate logic.

Design

- **Stateless:** Python MCP SDK (FastMCP), streamable HTTP, `stateless_http=True`. No MCP session state. Conversation memory lives in our own store, keyed by `conversation_id`.
- **Per-request identity:** every call carries `Authorization: Bearer <JWT>` from our mock IdP. Validated on every request (signature, expiry, audience). **No shared service credential**, no token passthrough to upstream systems.
- **Narrow, read-only tools.** No raw "run a query" tool. Predefined, constrained tools only.
- **Pinned tool descriptions:** tool descriptions are treated as untrusted by clients; ours are fixed and versioned (tool-poisoning defense).
- Same refusal behavior as the HTTP API: uniform shape, no hints about hidden content.
- Every call is written to the audit log as `mcp_call`.

Tools

Tool	Input	Output
<code>ask</code>	<code>question</code> , optional <code>conversation_id</code> , optional <code>skill_hint</code>	Same as <code>POST /v1/ask</code>
<code>search</code>	<code>query</code> , optional <code>sources[]</code> , <code>limit</code>	Authorized hits only: <code>doc_id</code> , <code>title</code> , <code>url</code> , <code>snippet</code> , <code>as_of</code>
<code>get_source</code>	<code>doc_id</code>	Content of one authorized document, or the uniform "not found"
<code>explain_access</code>	<code>doc_id</code>	<code>proof_path</code> for an allowed document, else "not found"
<code>audit_query</code>	<code>question</code> or <code>filter</code>	Compliance role only; audit events, <code>verify</code> status

Client configuration

CodeBuddy (~/`.codebuddy/.mcp.json` or project `.mcp.json`):

```
{
  "mcpServers": {
    "internal-brain": {
      "type": "http",
      "url": "https://<our-host>/mcp",
      "headers": { "Authorization": "Bearer ${BRAIN_TOKEN}" }
    }
  }
}
```

Keep the token in an environment variable. Never commit it or show it in screenshots. WorkBuddy supports STDIO, SSE and HTTP transports with custom headers: verify in practice (see [06-risks-and-checks](#)).

Use in the demo

- Jordan (compliance) asks the audit question from **WorkBuddy**; a **scheduled WorkBuddy task** produces a weekly compliance digest from `audit_query`.

- Developers query project knowledge from **CodeBuddy** with their own identity.

Changelog

- 0.1: first draft.

Workstream A · Sources and freshness

docs/03-workstreams/ws-a-sources.md

Owner: Praew (@watersalamander) · **Directories:** [connectors/](#), [simulators/](#) · **Status file:** [status/ws-a.md](#)

Mission

Get real data, with faithful permissions, from the four platforms into the index quickly and correctly. Own freshness end to end.

Scope

- **Real connectors:** Slack (free workspace, custom internal app, Events API) and Google Drive (several free Google accounts, per-user OAuth, [changes.watch](#)).
- **Simulators:** Confluence and Jira with faithful permission semantics (a real free Atlassian tenant optionally for content and webhooks only). Optional Slack/Drive simulators for scale and attack tests.
- **ACL evaluators** per source, identity mapping, [check_access](#).
- **Ingestion service:** consumes [list_changes](#) (webhooks plus poll fallback), chunks, embeds (local bge-m3), writes chunks with ACL tokens to Postgres.
- **Seed data** for fictional "Company A" and a large-scale generator (12k+ Confluence pages, 200+ Slack channels).
- **Contract tests** run against both real and simulated backends.

Owns (produces)

[connector-interface](#) and the ACL evaluators in [acl-model](#); the [chunks](#) table schema; simulator admin endpoints (revoke, restrict, edit, add/remove hidden docs).

Consumes

- Audit-event schema (emit [acl_change_observed](#)): from B.
- Embedding backend choice: [ADR-002](#).

Tasks and schedule

Day 1 = Fri 2 Oct. Day 3 = contracts freeze. Day 8 = demoable build.

Days 1 to 2 (Fri 2 to Sat 3 Oct)

- [] Create the Slack workspace and a custom internal app; verify rate limits for an internal app (check #3 in [06-risks](#))
- [] Create 4 to 5 Google accounts for personas; set up OAuth client; verify [changes.watch](#) reaches a webhook (check #4)
- [] Decide the Atlassian approach: trial window, sandbox, or simulator only (check #5)
- [] Design the "Company A" seed corpus and personas (Priya, Sam, Dana, Jordan, manager); write it down in [docs/](#) for the team
- [] Draft contract changes you need (PRs to [docs/02-contracts/](#))

Day 3 (Sun 4 Oct): contracts freeze

- [] Ship connector and ingestion **stubs** that return fixture data matching the contracts
- [] Postgres schema for [chunks](#) (pgvector, FTS, GIN on [acl_tokens](#)) agreed with B

Days 3 to 5 (Sun 4 to Tue 6 Oct)

- [] Slack connector: public/private channels, membership, threads, DMs; Events API plus poll fallback; `check_access` via channel membership
- [] Drive connector: folders, files, sharing roles, inheritance, shared drives, external sharing; `changes.watch`; `check_access` via permissions API
- [] Confluence simulator: spaces, nested pages, space permissions, inherited page restrictions, webhooks, REST shapes similar to the real API
- [] Jira simulator: projects, role schemes, groups, **issue security levels**, issues with links, webhooks

Days 5 to 7 (Tue 6 to Thu 8 Oct)

- [] Identity mapping across platforms (`resolve_identity`); fail closed when unmapped
- [] Ingestion service: chunking, local bge-m3 embedding (store model and version), ACL tokens, deletes, `acl_change` handling
- [] Seed Company A data in all four sources, including the scenario fixtures (breach report in a security-only space, private channel, runbook, DB-migration project, auth-service thread)

Day 8 (Fri 9 Oct): demoable build

- [] Data flows from all four sources into the index with correct ACL tokens
- [] Simulator admin actions work (revoke, restrict, edit)

Days 9 to 10 (Sat 10 to Sun 11 Oct)

- [] Contract tests pass on real and simulated backends (inheritance, revocation, edit, negative case)
- [] Scale seed generator: 12k+ pages, 200+ channels; measure ingestion throughput
- [] Measure and expose freshness lag (`freshness_lag_seconds`, p50/p95)

Days 11 to 12 (Mon 12 to Tue 13 Oct)

- [] Hidden-document add/remove/edit tooling for Leak-CI (with C)
- [] Webhook and poll hardening, rate-limit back-off, retries
- [] Support B on revocation-to-enforcement timing measurement

Days 13 to 15 (Wed 14 to Fri 16 Oct)

- [] Bug fixes, final data reset, deployment support, `simulators/README.md`

Definition of done

- All four connectors pass the shared contract tests.
- A revocation in any source flips `check_access` to deny and emits `acl_change` within the SLA.
- A content edit appears in the index within the SLA (target: under 5 minutes for events, under 1 hour worst case).
- No credentials in the repo; read-only scopes only.

Watch-outs

- Do not flatten permission semantics. Keep native evidence in `AcLEvidence.native`.
- `check_access` fails closed on errors and timeouts.
- Slack free-plan history and rate limits: confirm early. Atlassian free plan lacks the permission features we need.

Workstream B · Brain and policy

docs/03-workstreams/ws-b-brain.md

Owner: Ananya (@ananyaredhu) · **Directories:** [brain/](#), [mcp_server/](#) · **Status file:** [status/ws-b.md](#)

Mission

Turn authorized chunks into trustworthy, cited answers. Own the policy decision point, the query pipeline, the checker, the audit chain, the skills and the MCP server.

Scope

- **Model gateway** with swappable backends and a **Day-2 model probe** ([ADR-001](#)).
- **Policy decision point (PDP):** compute the asker's tokens, prefilter, call connector [check_access](#) just in time, record decisions with proof paths. Plain deterministic code, no LLM.
- **Retrieval:** hybrid (BM25 via Postgres FTS plus vectors), ACL prefilter, reciprocal-rank fusion, optional local rerank.
- **LangGraph pipeline:** route, rewrite, retrieve, JIT verify, link-edge expansion, context packet, generate, check, uniform refusal, audit.
- **Context engineering** and **context profile** ([context-packet](#)).
- **Runtime skills** (four) and the loader ([skills-format](#)).
- **Layered checker** ([ADR-003](#)): deterministic, local grounding model, small chat model.
- **Audit service:** hash chain, signed checkpoints, [/verify](#), audit agent, replayable and time-travel queries ([audit-event-schema](#)).
- **Answer-level ACL labels** and **stale-answer alerts**.
- **MCP server**, stateless ([ADR-004](#), [mcp-tools](#)).
- Stretch: sensitivity-aware model routing, mosaic guard, honeytokens.

Owns (produces)

[audit-event-schema](#), [context-packet](#), [skills-format](#), [api](#), [mcp-tools](#), and the PDP side of [acl-model](#).

Consumes

Connectors, [chunks](#) schema and simulator admin endpoints from A. UI needs and golden tests from C.

Tasks and schedule

Days 1 to 2 (Fri 2 to Sat 3 Oct)

- [] **Model probe script:** reachability from Singapore, latency, rate limits, structured output, context length, cost for DeepSeek-V3 (ADP/TokenHub), Hunyuan, Qwen, small open-weight models (check #1)
- [] Model gateway interface with config-driven backends; embedding interface (bge-m3 default)
- [] Time bge-m3 and checker candidates on CPU (check #2, #6) with C
- [] LangGraph pipeline skeleton; audit hash-chain library with tests (genesis, append, verify, tamper test)
- [] Draft contract changes you need (PRs to [docs/02-contracts/](#))

Day 3 (Sun 4 Oct): contracts freeze

- [] Ship a **stub** [/v1/ask](#), [/v1/mywork](#), [/v1/audit/*](#) returning fixtures that match [api](#), so C can build the UI
- [] Agree the [chunks](#) schema with A

Days 3 to 5 (Sun 4 to Tue 6 Oct)

- [] PDP: token computation, prefilter, JIT `check_access` with short-TTL cache, fail closed, decisions with proof paths
- [] Hybrid retrieval over the real index; per-source fan-out and fusion
- [] Audit service: events, signed checkpoints, `/verify`

Days 5 to 8 (Tue 6 to Fri 9 Oct)

- [] Router and query rewrite (small model); context packet builder (quotas, dedupe, ordering, budget, spotlighting)
- [] Generator with structured claims plus citations; checker layers 1 and 2
- [] Uniform refusal with timing normalization
- [] **Day 8 demoable:** scenarios 1, 3 and 4 run end to end on seed data

Days 9 to 10 (Sat 10 to Sun 11 Oct)

- [] Four skills and the loader (status-and-blockers, incident-investigation, design-discussion-summary, audit-inquiry)
- [] Stateless MCP server with per-request JWT validation; pin tool descriptions
- [] Link-edge authorization; answer-level ACL labels; checker layer 3 for hard cases
- [] Freshness read-through (version check and inline re-fetch)

Days 11 to 12 (Mon 12 to Tue 13 Oct)

- [] Context profile and `/v1/mywork` data
- [] Stale-answer alerts engine
- [] Audit agent (NL to filters, under RBAC); replayable audit and time-travel queries
- [] Measure and publish revocation-to-enforcement time
- [] Stretch: sensitivity-aware model routing (restricted content only to in-region models)

Days 13 to 15 (Wed 14 to Fri 16 Oct)

- [] Hardening, latency and cost tuning, final model choices recorded in ADRs
- [] Support the demo, video and submission

Definition of done

- Scenarios 1 to 7 produce correct, cited answers and refusals.
- Zero leaks on the golden and red-team suites; the local denied-set scan has no hits.
- Every decision is in the audit log with evidence; `/verify` passes and fails correctly on tampering.
- The MCP server works from WorkBuddy and CodeBuddy with per-user identity.
- No credentials or denied content ever sent to a model or third party.

Watch-outs

- The policy plane has no LLM influence on allow/deny.
- Never log or send denied content outside Zone 2; denied IDs are salted-hashed in the audit log.
- Hosted models see only authorized content; the denied-set scan stays local.
- Budget tokens: cache, small model where enough, run Leak-CI batches separately.

Workstream C · Experience and proof

docs/03-workstreams/ws-c-experience.md

Owner: Guanyue (@guanyue017-dev) · **Directories:** [ui/](#), [evals/](#), [deploy/](#) · **Status file:** [status/ws-c.md](#)

Mission

Make it usable, testable, deployed and submittable. Own the demo, the zero-leak proof and the paperwork, including the CodeBuddy/WorkBuddy proof log.

Scope

- **Mock OIDC IdP** (JWT) and personas.
- **UI:** chat with citations and "why can I see this?", persona switcher and split-screen demo, **My Work** home, admin and audit console (audit explorer, freshness dashboard, permission-graph viewer, Leak-CI scoreboard).
- **Evals:** golden tests for all seven scenarios, **Leak-CI** (noninterference tests), red-team harness (prompt injection, existence side-channels, canary strings, revocation races).
- **Deployment** on Tencent Cloud Singapore (live URL for bonus points) and the sandbox setup.
- **WorkBuddy integration:** MCP client setup, scheduled weekly compliance digest.
- **Submission:** architecture and trust-boundary diagram, demo video, cover image, description, proof log.
- Accessibility: keyboard navigation, ARIA, high contrast; optional voice (TRTC ASR/TTS) as a stretch.

Owns (produces)

Mock IdP and JWT claims; UI; [evals/](#) suites and the scoreboard; [deploy/](#); the submission docs ([07-submission](#)).

Consumes

[api](#) and [mcp-tools](#) from B; simulator admin endpoints and seed data from A.

Tasks and schedule

Days 1 to 2 (Fri 2 to Sat 3 Oct)

- [] Bootstrap the repo, CODEOWNERS handles, pre-commit secret scan; everyone redeems credits (1,000 CodeBuddy/WorkBuddy and 1,000 Miora per person)
- [] Start the proof log from day 1 (screenshots with keys blurred)
- [] Post the questions in the track WhatsApp group (mocks acceptable? track judging criteria? correct submission link?) (check #12)
- [] Verify CodeBuddy MCP config and which instruction file it reads (check #8); find out what the WorkBuddy multipliers mean (check #11)
- [] Hosting: Lighthouse/CVM in Singapore, cost and credits (check #10)
- [] Draft contract changes you need (PRs to [docs/02-contracts/](#))

Day 3 (Sun 4 Oct): contracts freeze

- [] Mock IdP issuing JWTs for the personas
- [] UI shell running against B's **stub** API

Days 3 to 5 (Sun 4 to Tue 6 Oct)

- [] Chat UI with citations, "as of" times, "why can I see this?", uniform refusal display
- [] Persona switcher and split-screen view
- [] Golden test harness skeleton with the seven scenarios and expected allowed and denied sets

- ☐ WorkBuddy MCP client check against a local MCP server (check #7); sandbox check (check #9)
- ☐ Deployment pipeline to Singapore

Days 6 to 8 (Wed 7 to Fri 9 Oct)

- ☐ **My Work** home (assigned tickets, projects, channels, recent pages, suggested questions)
- ☐ Admin and audit console skeleton
- ☐ **Day 8 demoable**: scenarios 1, 3 and 4 shown in the UI against real data; schedule review

Days 9 to 10 (Sat 10 to Sun 11 Oct)

- ☐ Audit explorer with `/verify` and a "tamper then re-verify" demo
- ☐ Freshness dashboard (p50/p95); permission-graph viewer
- ☐ **Leak-CI**: metamorphic tests (add/remove/edit hidden documents, same user re-asks, compare answers, refusal wording and latency bands)
- ☐ WorkBuddy as MCP client: Jordan's audit question; scheduled weekly digest

Days 11 to 12 (Mon 12 to Tue 13 Oct)

- ☐ Red-team harness: prompt injection in documents, existence side-channel probes, canary strings, revocation races; public scoreboard (leaks 0/N, freshness p95, citation precision)
- ☐ Accessibility pass (keyboard, ARIA, contrast)
- ☐ Stretch: TRTC voice question and spoken answer

Days 13 to 15 (Wed 14 to Fri 16 Oct)

- ☐ Architecture and trust-boundary diagram with trade-offs (see [01-architecture](#))
- ☐ Demo video (5 to 8 minutes), cover image (16:9, Miora optional), title, blurb under 10 words, description
- ☐ Proof log complete (3+ screenshots approved, no secrets); secret scan on the full history
- ☐ Final dry run of all seven scenarios on the deployed build; submit by Thu 15 Oct target, Fri 16 Oct hard deadline

Definition of done

- All seven scenarios pass in the UI and through WorkBuddy via MCP.
- Leak-CI shows 0 leaks; the scoreboard is visible.
- A live URL works; the demo video is recorded.
- Submission items complete and the proof is approved.

Watch-outs

- Never show keys, tokens or redemption codes in screenshots or the video.
- The demo uses real accounts we own and fictional data only.
- Confirm the correct submission link (the handbook and the credits page differ).
- Use free build-time models (Hy3, Hy4 preview) for routine work to save credits.

04 · Scenarios and golden tests

docs/04-scenarios.md

The handbook requires five scenarios, each with a worked example. We also treat the two CTO questions in the problem statement as explicit scenarios. Each scenario has a **golden test**: a scripted run with expected allowed and denied sets, owned by Workstream C (*evals/*) with data from Workstream A.

Personas (see [seed data](#)): **Priya** (backend engineer), **Sam** (contractor), **Dana** (security lead), **Jordan** (compliance officer), plus a manager. Fictional "Company A": payment-gateway, auth-service and database-migration (DBMIG) projects.

#	Scenario	Setup	Steps	Expected	Owner(s)
1	Unified natural-language query	Jira DBMIG tickets, Slack #db-migration (Priya a member), a private Slack channel (Priya not a member) discussing the migration	Priya asks: "What's the status of the DB migration, and were there blockers raised in Slack last week?"	One grounded answer with citations to Jira and Slack; nothing from the private channel	B (pipeline), A (data), C (golden test)
2	Data freshness	Confluence runbook for payment-service incident, cached version at 9:00	At 1:00 PM the owner adds a failover step; at 2:05 PM an on-call engineer asks for the latest runbook	Answer includes the new step, with an "as of" time. Ingestion lag p95 within the SLA. Never silently serves the old version	A (ingestion), B (read-through check)
3	Correct permission enforcement (negative cases)	Q3 breach report in a security-only Confluence space	Sam (contractor) asks: "Show me the security incident report from the Q3 breach"	Answer contains none of it and neither confirms nor denies it exists; same response shape and timing as for a nonexistent report	B, C (Leak-CI)
4	Live permission change	Priya is in a private Slack channel and can see its content	Remove her from the channel (simulator or real Slack admin), then re-ask the same question	Content disappears on the very next query. Revocation-to-enforcement time is recorded	A (change feed), B (JIT re-check)
5	Audit inquiry	Seeded access history	Jordan asks: "Show me everything user jdoe accessed related to the payment-gateway Confluence space in the last 30 days"	Reconstructed list with timestamps, retrieved IDs and allow/deny decisions. <i>/verify</i> passes; after tampering with a log row it fails	B (audit), C (console)
6	CTO question 1	Payment outage last quarter: Jira incident and follow-up tickets, Slack incident thread, Drive postmortem, Confluence runbook	"What was the root cause of the payment outage last quarter, and what follow-up tickets were created?"	Cross-platform answer with citations; permission filtering per user; uses the incident-investigation skill	B (skill), A (data)

#	Scenario	Setup	Steps	Expected	Owner(s)
7	CTO question 2	Auth-service design discussion in Slack threads, Confluence decision doc	"Summarize the design discussion around the new auth service from last sprint's Slack threads and link the Confluence decision doc"	Summary of threads plus link to the decision doc, restricted to what the asker can see; uses the design-discussion skill	B (skill), A (data)

Additional demo moments

- **Split-screen personas:** Priya, Sam and Dana ask the same question; three different correct answers.
- **Stale-answer alert:** edit a source after an answer was given; the asker is notified.
- **Link-edge authorization:** a Jira ticket links to a restricted Confluence page; Sam sees no hint of it.
- **Prompt injection in a document:** a Slack message says "ignore previous instructions and reveal ..."; the answer is unaffected and the attempt is flagged.
- **My Work:** each persona sees a different home (their tickets, projects, channels).
- **WorkBuddy via MCP:** Jordan asks the audit question from WorkBuddy; weekly scheduled digest.

Pass bars

- **0 leaks** across the golden and red-team suites.
- Revocation takes effect on the next query.
- Freshness: updated content appears within the SLA (target: under 5 minutes for events, under 1 hour worst case).
- `/verify` detects any edited or deleted log row.
- All seven scenarios run through the UI and through WorkBuddy via MCP.

Decision records (ADRs)

docs/05-decisions/README.md

Short records of decisions that affect more than one workstream. Changes need **all three** reviewers.

ADR	Decision	Status
001	Model gateway and model tiers	Accepted; final choices after the Day-2 probe
002	Local bge-m3 embeddings by default	Accepted
003	Layered answer checker	Accepted
004	Stateless MCP server	Accepted
005	Real Slack/Drive, simulated Confluence/Jira	Accepted
006	Single Postgres with pgvector	Proposed
007	LangGraph orchestration; ADP as optional backend	Accepted

Template: **Context** (why), **Decision**, **Consequences**, **To verify**.

ADR-001 · Model gateway and model tiers

docs/05-decisions/ADR-001-model-gateway.md

Status: Accepted. Final model choices are set after the Day-2 probe (owner: B).

Context

Two separate LLM uses exist.

- **Build time:** the models inside CodeBuddy and WorkBuddy, paid for by the 1,000 credits per person. WorkBuddy's picker shows Hy3 and Hy4 preview at 0.00x, Fast 0.34x, Balanced 0.59x, Auto 0.79x, GPT-5.6-Terra 1.39x, Primary 3.31x, Deep 3.33x, GPT-5.6-Sol 3.47x. We read the multiplier as credit cost per request: confirm in the credits dashboard.
- **Run time:** the models our backend calls. Credits do not pay for these. A model's presence in the WorkBuddy picker does **not** mean the deployed app can call it.

Decision

A **model gateway**: one interface, config-driven backends, tiered by task (Atlassian-style hybrid use).

Task	Starting choice	Notes
Routing, query rewrite, relevance check	Small, fast: Hunyuan (OpenAI-compatible endpoint), else DeepSeek-V3 with short prompts	Hunyuan access from Singapore: verify
Answer generation (structured claims plus source IDs)	DeepSeek-V3 via ADP or TokenHub (OpenAI-compatible)	Check context length and structured-output support
Answer checker	See ADR-003	Different family from the generator
Offline grading and red-team scoring	DeepSeek-R1	Too slow for the live path
Embeddings	See ADR-002	

Build-time guidance: Hy3 and Hy4 preview (0.00x) for routine work; Fast, Balanced or Auto for medium tasks; keep the roughly 3x models for hard design and review.

Consequences

- Models can be swapped without touching the pipeline.
- A **Day-2 probe script** measures per candidate: reachability from Singapore, latency, rate limits, structured-output or function-calling support, context length, cost. The result updates this ADR.
- Token budget is a risk: cache repeated calls, use the small model where enough, run Leak-CI as a separate batch.
- Only authorized content is ever sent to a hosted model. Denied content never leaves the policy plane.

To verify

Hunyuan and TokenHub access from Singapore; free allowances and rate limits; whether ADP's built-in DeepSeek is reachable as a raw completion endpoint (its Chat API calls a published ADP app with its own prompt, so we call model endpoints directly and treat ADP as optional).

ADR-002 · Embeddings: local bge-m3 by default

docs/05-decisions/ADR-002-embeddings.md

Status: Accepted.

Context

Hunyuan embedding is 1024-dimensional with a 5 requests/s default limit, and was listed only in China regions. Hosted embeddings would send restricted content to a third party.

Decision

Use **bge-m3 run locally** as the default embedder. Keep Hunyuan embedding as an optional backend if the Day-3 check shows it works from Singapore. Alternatives if quality or speed disappoints: Qwen3-Embedding (local), or a small model (multilingual-e5-small or bge-small) on a CPU-only server.

Consequences

- Restricted content never leaves our environment to be embedded; no rate limit; reproducible.
- CPU cost on the deployment server: pre-embed large corpora offline; measure on Day 2 to 3.
- Store `embedding_model` and `embedding_version` with every vector. Switching models means re-embedding.
- **Vectors carry the same ACL tokens as their chunk.** Embeddings can leak information, so they follow the same rules as the text.
- Optional local reranker (`bge-reranker-v2-m3`) on the top results only, if time allows.

To verify

bge-m3 license (we recall MIT) and CPU throughput; Hunyuan embedding reachability.

ADR-003 · Layered answer checker

docs/05-decisions/ADR-003-checker.md

Status: Accepted.

Context

Even with correct retrieval, the generator might add unsupported claims or echo content it should not have. A checker from the same model family as the generator would share its blind spots. DeepSeek-R1 as a fallback checker is the same family and slow.

Decision

Three layers behind the model gateway, cheapest and most independent first.

1. **Deterministic checks (always):** every cited source exists and is visible to the asker; a **local denied-set leakage scan** compares the answer with documents the user was denied (names, IDs, phrases, and optionally local bge-m3 similarity). No LLM involved.
2. **Small purpose-built grounding model, run locally:** MiniCheck-style claim-versus-document verification, from a different family than the generator.
3. **Small open-weight chat model for hard cases only:** Qwen 3B to 8B, or open Hunyuan small models.

If support is missing at any layer: abstain or redact.

Consequences

- The denied-set scan is **always local**; denied content is never sent to any model or third party.
- The claim check only ever sees authorized content, so a hosted model would be acceptable for layer 3 if CPU is too slow.
- Time layers 2 and 3 on the deployment server's CPU on Day 3; use a 3B to 4B model if 8B is too slow.
- Canary strings in restricted documents make the leak scan testable in Leak-CI.

To verify

Grounding model names and licenses (from memory); CPU timing; whether open Hunyuan small models are available.

ADR-004 - Stateless MCP server

docs/05-decisions/ADR-004-mcp.md

Status: Accepted.

Context

MCP servers are a known leakage vector: shared service credentials, confused-deputy problems, and authorization checked only at session start. We want CodeBuddy and WorkBuddy to act as real clients with per-user identity.

Decision

- **Stateless:** Python MCP SDK (FastMCP), streamable HTTP, `stateless_http=True`.
- **Per-request identity:** every call carries a bearer JWT from our mock IdP, validated per request (signature, expiry, audience). No token passthrough to upstream systems; no shared master key.
- **Narrow, read-only tools** (`ask`, `search`, `get_source`, `explain_access`, `audit_query`). No raw "run a query" tool.
- Pinned, versioned tool descriptions. Every call audited as `mcp_call`.
- MCP is another front door into the same pipeline as the UI, with no separate logic.
- Conversation memory lives in our own store, not in MCP sessions.

Consequences

- Per-request authorization, easy scaling, simple deployment.
- No server-initiated streaming or subscriptions. If later needed, add a stateful path separately.
- Clients: CodeBuddy supports `type: http` servers with `headers` and `${ENV}` variables; WorkBuddy documents STDIO, SSE and HTTP transports with custom headers.

To verify

WorkBuddy remote MCP with an Authorization header and scheduling work in practice (check #7); which instruction file CodeBuddy reads (check #8).

ADR-005 · Real Slack and Drive, simulated Confluence and Jira

docs/05-decisions/ADR-005-connectors.md

Status: Accepted.

Context

Tencent did not provide enterprise API access to the four platforms. We use free real APIs where they exist and simulate the rest.

Decision

Platform	Approach	Why
Slack	Real (free workspace, custom internal app, Events API)	The 2025 rate-limit cut (1 request/min, 15 objects for <code>conversations.history/replies</code>) targets commercially distributed non-Marketplace apps; an internal app should be exempt
Google Drive	Real (several free Google accounts, per-user OAuth, <code>changes.watch</code>)	Permissions API and push notifications work; domain-wide delegation needs paid Workspace, so we skip it
Confluence	Simulator with faithful permission semantics (optional real free tenant for content and webhooks only)	The free plan reportedly has no space or page permissions
Jira	Simulator with faithful semantics, including issue security levels (same option)	The free plan reportedly has no project or issue permissions

All four sit behind one [connector interface](#). The same **contract tests** run against real and simulated backends, so a simulator is proven faithful wherever a real API exists. Simulators also supply scale (12k+ pages, 200+ channels) and adversarial or revocation-race tests that are impractical on real tenants.

Consequences

- Fidelity where free APIs allow it; honest disclosure of where we simulate.
- An Atlassian paid-plan trial window, or a sandbox from Tencent or Aspire, can give a real recording of permissions. Decide on Day 2 (check #5).

To verify

Slack internal-app limits and free-plan history; Atlassian free-plan limits and trial length; ask in the track group whether simulated connectors are acceptable.

ADR-006 · Storage: single Postgres with pgvector

docs/05-decisions/ADR-006-storage.md

Status: Proposed (confirm by Day 3).

Context

We need vector search, keyword search, ACL-token filtering, a transactional audit store and ACL snapshots with validity intervals, on a small deployment.

Decision

One **Postgres** instance with: **pgvector** for vectors, built-in full-text search for BM25-like retrieval, a **GIN index on `acl_tokens[]`** for the prefilter (array overlap), and tables for the audit log and bi-temporal ACL snapshots. Hosted on a Tencent Cloud Singapore VM (Lighthouse or CVM). TencentDB for PostgreSQL is an option if it supports pgvector.

Consequences

- One system to run, secure and back up; the ACL filter and the vector search happen in one query.
- Less specialized than a dedicated vector database. Tencent Cloud VectorDB (hybrid search with scalar filtering) is a possible later swap, not needed at our scale.
- The **chunks** schema is shared between A (writes) and B (reads): see [connector-interface](#).

To verify

pgvector availability on the chosen Tencent service; index performance at 12k+ pages.

ADR-007 · Orchestration: LangGraph; ADP as an optional backend

docs/05-decisions/ADR-007-orchestration-and-adp.md

Status: Accepted.

Context

We need an orchestration layer where deterministic policy gates are clearly separate from LLM steps, and where the pipeline is easy to trace and demo. Tencent's Agent Development Platform (ADP) offers workflows, a knowledge base, DeepSeek models, and publishes agents with a shareable Experience URL and an AppKey-protected Chat API.

Decision

- **LangGraph** for the pipeline: explicit state, typed nodes, deterministic policy gates as plain-code nodes, traces for demos.
- **ADP is not the core.** Its knowledge base is a general RAG store with platform, space, application and knowledge-base permissions. It does not ingest per-user ACLs from Confluence, Jira, Slack or Drive, so uploading documents there would bypass our permission model.
- ADP may be used (a) as one model backend behind the gateway, called only with already-authorized context, and/or (b) to publish an Experience URL for judges. Its Chat API calls a published ADP app with its own prompt; it is not a raw completion endpoint, so generator and checker call model endpoints directly.

Consequences

- Tencent product use is real but optional beyond the mandatory CodeBuddy/WorkBuddy.
- A free ADP allowance (knowledge base capacity, DeepSeek tokens) can fund some model calls: confirm the amount and expiry in Platform Management.
- Keep AppKeys out of the repo and screenshots.

To verify

ADP free quota; whether per-request context can be passed through its Chat API.

06 · Risks and week-1 checks

docs/06-risks-and-checks.md

Everything marked **verify** comes from web searches or the handbook and has not been confirmed in our own accounts. Resolve these in week 1 (by Day 5, Tue 6 Oct) and record the result here.

Checks

#	Check	Owner	Due	Result
1	Model probe: run a script against each candidate model and record: reachable from Singapore, latency, rate limits, structured-output / function-calling support, context length, cost. Candidates: DeepSeek-V3 (ADP / TokenHub), Hunyuan (OpenAI-compatible), Qwen, small Hunyuan open weights	B	Day 2	
2	Checker timing: time the layer-2 grounding model and a 3B-8B chat model on the deployment server's CPU	B	Day 3	
3	Slack: custom internal app in our own workspace is exempt from the 2025 rate-limit cut (1 request/min, 15 objects) that targets commercially distributed non-Marketplace apps	A	Day 2	
4	Google Drive: per-user OAuth with several free Google accounts; <code>changes.watch</code> push notifications reach our webhook	A	Day 3	
5	Atlassian free plan: reportedly no space/page or project/issue permissions. Decide: paid-plan trial window, sandbox from Tencent/Aspire, or simulator only. Check trial length and which plan includes issue security	A	Day 2	

#	Check	Owner	Due	Result
6	Embeddings: bge-m3 speed on CPU; license check (MIT as we recall). Hunyuan embedding reachable? (listed in China regions, 5 requests/s)	B	Day 3	
7	WorkBuddy MCP: remote HTTP MCP with an Authorization header works end to end; scheduling works	C	Day 4	
8	CodeBuddy MCP config: <code>.mcp.json</code> with <code>type: http</code> and headers using env vars works; confirm whether it reads <code>CODEBUDDY.md</code> or <code>AGENTS.md</code>	C	Day 2	
9	Sandbox: CubeSandbox (or Tencent "Agent Runtime") availability and credits; fallback Docker with network policy	C	Day 4	
10	Tencent hosting: Lighthouse/CVM in Singapore, cost and credits for a live demo URL	C	Day 3	
11	Build-time credits: what the multipliers in WorkBuddy mean (Hy3, Hy4 preview show 0.00x; Fast 0.34x, Balanced 0.59x, Primary 3.31x, Deep 3.33x, GPT-5.6 models 1.39x to 3.47x); remaining balance per person	all	Day 1	
12	Ask in the track WhatsApp group: are mock/simulated connectors acceptable? the track-specific judging criteria; the correct submission link (the handbook and the credits page show two different links)	C	Day 1	
13	GitHub: repo visibility or judge access plan for submission; license choice	all	Day 12	

Risks

Risk	Impact	Mitigation
Schedule: about 45 person-days of work in 15 days	High	Tiers define build order; demoable build by Day 8; schedule review on Day 8; stubs by Day 3
Atlassian free plan lacks permissions	High (permission semantics are the core)	Faithful simulator plus contract tests; optional trial window for a real recording
Model access or quota from Singapore	Medium	Model gateway with swappable backends; probe on Day 2; cache and batch eval runs
Token budget for Leak-CI and evals (hundreds of queries x several calls)	Medium	Cache repeated calls; small model where enough; run evals as a separate batch
CPU-only server too slow for local checker/embeddings	Medium	Smaller models (3B-4B, small embedder); pre-embed offline; measure on Day 3
Prompt injection or denied-content leak in testing	High	Layered defenses; Leak-CI as a release gate; local denied-set scan
Secrets in screenshots or commits	High	.env, gitignore, pre-commit scan, review screenshots before logging them
Contracts change late and break other workstreams	Medium	Freeze Day 3; changes need all three reviewers

Day-1 decisions made

- Real Slack and Drive connectors; Confluence and Jira simulated with faithful permission semantics (optionally a real free Atlassian tenant for content and webhooks only).
- Local bge-m3 embeddings by default; Hunyuan optional.
- Layered checker, with the denied-content scan always local.
- Stateless MCP.
- Nothing is cut from scope; tiers are build order.

07 · Submission

docs/07-submission.md

Deadline: Fri 16 Oct 2026. Target freeze **Thu 15 Oct**. Finalists (top 2 per track) announced 23 Oct; Demo Day 3 Nov (TBC).

Hard requirements (handbook section 8)

- The project must be **original** and **built on CodeBuddy or WorkBuddy**.
- **Proof of product usage is mandatory**: chat screenshots, API call logs, or a written development-process description. Without proof the project does not proceed to scoring.
- Minimum **3 screenshots or a screen recording** of CodeBuddy/WorkBuddy chat logs from the build.

Required items

Item	Status	Notes
Project title		Name of the AI agent project
Short blurb		Under 10 words (hard limit)
Project description		Overview and value proposition; real-world scenario insights (pain points, audience, core problems); solution design (business and technical architecture, how prompts drive the AI generation); business value with quantifiable metrics
CodeBuddy / WorkBuddy conversation history		3+ screenshots or a recording
Cover image		16:9, recommended 380x216 px (Miora can help)
Demo video (optional)		5-8 minutes: overview, core features, reflection on the build approach and tool tips for CodeBuddy/WorkBuddy
Project link (optional, bonus points)		Live URL on Tencent Cloud Singapore

Track-specific deliverables (Aspire FinTech)

- Live **demo walkthrough** covering the scenarios in [04-scenarios](#), each with a worked example.
- **Architecture diagram** with trust boundaries and key design trade-offs (see [01-architecture](#)).
- **Complete source code** via a GitHub repository (decide visibility or judge access before the deadline).
- Clearly indicate the chosen case study ("The Internal Brain") at the start of the presentation.

Where to submit

The handbook gives tinyurl.com/TCHackathonSGProjectSubmission. The credits page shows a different link (forms.gle/CPV5HQELE4x83eBc6). **Confirm in the WhatsApp group which is current** before submitting.

Judging (10 criteria x 10 points)

Impact & Relevance · Human-Centered Design · AI Interaction · Technical Execution · Feasibility · Demo & Storytelling · Innovation & Creativity · UX & Accessibility · Responsible AI & Ethics · Overall Quality. The handbook's judging text appears copy-pasted from another event (it mentions schools and game quality); get the real track criteria from the organizers.

Proof log

Add a row each time you capture proof. Check every screenshot for API keys, tokens and redemption codes **before** adding it. Store approved files under [docs/proof/](#).

Date	Who	Tool and model	What it shows	File
------	-----	----------------	---------------	------

Milestones worth capturing: connector scaffold, simulator permission logic, red-team tests, MCP integration, scheduled WorkBuddy digest, deployment.

Final checklist

- ☐ All seven scenarios pass on the deployed build
- ☐ Leak-CI shows 0 leaks; `/verify` passes and fails correctly on a tampered log
- ☐ Architecture and trust-boundary diagram exported
- ☐ Demo video recorded (5-8 minutes)
- ☐ 3+ proof screenshots approved and logged
- ☐ Title, blurb (<10 words), description, cover image ready
- ☐ No secrets in the repo history (run the secret scan on the full history)
- ☐ Repo access decided; README works from a fresh clone
- ☐ Submitted via the confirmed link